# PLATEFORME DE TRAITEMENT DES PAIEMENTS

## SECURITE ET CONFORMITE

| Nature du document | |
|---|---|
| Version | **2.0** |
| Client | **Étude de cas – STRIPE** |
| Date de la version | **12/10/2026** |
| Description de la version | **Bloc 2 - certification RNCP41993** |
| Modules concernés | **Livrable 6** |
| Auteur | **Ronan GUILLOU** |

# Table des matières


**1 Concepts clés ..... 3**
1.1 Définitions ..... 3
1.2 Principes ..... 3
**2 Vue d'ensemble ..... 3**
2.1 Cadre réglementaire ..... 3
2.2 Alignement avec la gouvernance des données ..... 4
2.3 Classification des données par système ..... 4
**3 Protection des données ..... 4**
3.1 Données ..... 4
3.2 Clés et secrets ..... 5
3.3 Tokenisation des cartes ..... 5
3.4 Droits des personnes ..... 5
3.5 Tableau de synthèse ..... 5
**4 Contrôle des accès ..... 6**
4.1 RBAC ..... 6
4.2 Mise en œuvre ..... 6
4.3 Segmentation réseau ..... 6
**5 Journal d'audit ..... 7**
5.1 Ce qui est journalisé et où ..... 7
5.2 Protection des journaux ..... 7
**6 Surveillance et rapports ..... 7**
6.1 Surveillance continue ..... 7
6.2 Contrôles et rapports quotidiens ..... 7
6.3 Incident et notification de violation ..... 7


### Note sur l'usage de l'intelligence artificielle

Pour rédiger ce document, j'ai utilisé un assistant d'IA générative comme outil d'aide à la rédaction. Il est intervenu sur quatre points : la correction de l'orthographe et de la syntaxe, la proposition de structures et de brouillons de texte que j'ai relus et modifiés, la comparaison d'idées et d'options avant décision, et la vérification de la cohérence d'ensemble.

Les choix retenus, la sélection des besoins et la validation finale de chaque chapitre relèvent de ma responsabilité.

# 1 Concepts clés

La confiance des marchands et des clients repose sur la protection de leurs données de paiement et de leurs données personnelles, encadrées par des règles strictes qui varient selon les pays (RGPD, CCPA, PCI-DSS). L'enjeu de ce plan est de protéger ces données à chaque étape, de limiter les accès au nécessaire et de prouver la conformité automatiquement.

## 1.1 Définitions

| Terme | Définition |
|---|---|
| **KMS** | Key Management Service : service AWS qui crée, stocke et fait tourner les clés de chiffrement. |
| **Secret** | Information d'accès (mot de passe, clé d'API, certificat) qui ne doit jamais figurer dans le code. |
| **Pseudonymisation** | Remplacement d'un identifiant par un code. Le lien reste possible avec une information conservée à part. |
| **Anonymisation** | Suppression irréversible du lien avec la personne. La donnée n'est plus personnelle. |
| **Tokenisation** | Remplacement d'un numéro de carte par un jeton sans valeur. Le numéro réel reste dans un coffre isolé, hors du périmètre de ce plan. |
| **RBAC** | Role-Based Access Control : les droits sont attribués à des rôles, non à des personnes. |
| **Moindre privilège** | Chaque rôle n'a que les droits nécessaires à sa mission. |
| **Résidence des données** | Obligation de garder certaines données dans une zone géographique donnée. |

## 1.2 Principes

- **La sécurité est intégrée dès la conception.** Chaque brique du diagramme (livrable 7) est protégée par défaut, sans réglage manuel.
- **Aucun numéro de carte n'est stocké.** Seuls un jeton, la marque et les quatre derniers chiffres sont conservés, ce qui réduit le périmètre PCI-DSS.
- **Chaque rôle n'a que les droits dont il a besoin**, accordés par rôle et jamais par personne.
- **La donnée personnelle est protégée par défaut.** Elle est pseudonymisée dans les systèmes d'analyse et de scoring, et anonymisée quand une personne demande son effacement.
- **Les secrets ne sont jamais dans le code.** Ils sont stockés dans un coffre et renouvelés régulièrement.
- **Tout est journalisé, rien n'est copié.** Les journaux enregistrent les actions, jamais les valeurs personnelles.
- **La conformité se prouve automatiquement.** Des contrôles planifiés et des rapports remplacent les vérifications manuelles.

# 2 Vue d'ensemble

Les données de la plateforme circulent dans cinq systèmes et relèvent de règles différentes selon le pays : ce chapitre pose le cadre dans lequel s'inscrivent les mesures des chapitres suivants.

## 2.1 Cadre réglementaire

Trois réglementations s'appliquent à la plateforme. Elles se recoupent en partie : une même mesure répond souvent à plusieurs d'entre elles. Le tableau rappelle ce que chacune impose et ce que cela change pour l'architecture. Les mesures correspondantes sont détaillées dans les chapitres suivants.

| Réglementation | Périmètre | Ce qu'elle impose | Impact sur le projet |
|---|---|---|---|
| **RGPD** | Données personnelles des personnes résidant dans l'Union européenne | Minimiser les données collectées, limiter leur durée de conservation, protéger les données, répondre aux demandes d'accès et d'effacement sous un mois, notifier une violation à l'autorité sous 72 h, garder les données de l'UE dans l'UE (résidence) | Pseudonymisation par défaut, effacement possible dans toutes les couches (Aurora, Bronze, Silver, Gold, DocumentDB, Redis), durées de conservation (TTL), hébergement en région européenne, procédure de notification d'incident |
| **CCPA** | Données personnelles des résidents de Californie | Droit de savoir quelles données sont collectées, droit de les faire | Même parcours de demande que le RGPD, avec un suivi dans data_subject_request. |

| | | | |
|---|---|---|---|
| | | supprimer, droit de refuser leur vente ou leur partage | |
| **PCI-DSS** | Toute donnée de carte de paiement, quel que soit le pays | Ne pas stocker les données sensibles de la carte, chiffrer celles qui sont conservées, contrôler et journaliser les accès, segmenter le réseau, tester et surveiller régulièrement | Aucun numéro de carte stocké (jeton, marque, 4 derniers chiffres), accès restreints par rôle, journal d'audit, réseau segmenté, surveillance continue |

## 2.2 Alignement avec la gouvernance des données

Ce plan de sécurité applique la politique de gouvernance des données définie au Bloc 1 (livrable 2), les rôles CDO, DPO, Data Owners, Data Stewards, équipe Sécurité et plateforme, et Model Owner interviennent dans ce plan.

Le CDO arbitre les règles de classification et de conservation, les Data Stewards contrôlent leur application, les Data Owners valident les accès, le DPO instruit les demandes des personnes, l'équipe plateforme exécute les opérations techniques et l'équipe Sécurité exploite la surveillance et les rapports. Le Model Owner veille à la sécurité des données utilisées par les modèles.

## 2.3 Classification des données par système

Chaque système de la plateforme contient des données de sensibilité différente. Le tableau indique, pour chacun, les données sensibles qu'il héberge, leur niveau de protection et leur durée de conservation.

| Système | Données sensibles | Niveau | Durée de conservation |
|---|---|---|---|
| **Customer** (OLTP) | E-mail, nom | **Critique** | Durée de la relation, anonymisation sur demande |
| **payment_method** (OLTP) | Jeton, marque, 4 derniers chiffres, fingerprint | **Critique** | Durée de la relation, puis suppression |
| **transaction, payment_item, fraud_assessment** (OLTP) | Montants, adresse IP, device_id, session_id, score de fraude | Sensible | Durée légale de conservation des paiements |
| **outbox** (OLTP) | Événements de paiement en attente de publication | Sensible | Courte : supprimée après publication |
| **Kafka** | Messages de paiement et de collecte | Sensible | Rétention courte, quelques jours |
| **Bronze** (Lakehouse) | Message brut tel que reçu, donc données personnelles | **Critique** | Alignée sur celle des paiements, effacement sur demande |
| **Silver** (Lakehouse) | Données nettoyées, identifiants clients | Sensible | Alignée sur Bronze |
| **Gold** (Lakehouse) | Faits et dimensions sans e-mail ni nom, features par client | Sensible | Alignée sur Bronze, reconstruit après effacement |
| **DocumentDB** | Sessions, clics, avis en texte libre, signaux de comportement (ip_hash, device_id) | Sensible | 90 jours (par TTL) |
| **Redis** (ElastiCache) | Compteurs de fraude, clés pseudonymisées | Sensible | Courte, selon le TTL de chaque compteur |
| **MLflow / modèles** | Modèles et jeux d'entraînement issus de Gold | Sensible | Une version par entraînement |

**Critique** : données de paiement et données personnelles directes. **Sensible** : données pseudonymisées ou comportementales.

Les données critiques sont concentrées dans deux endroits : customer et payment_method dans Aurora, et Bronze dans le lakehouse. Les protections les plus fortes se concentrent donc là, et les autres systèmes ne reçoivent que des données pseudonymisées.

# 3 Protection des données

Les données de la plateforme sont exposées à deux moments : quand elles sont stockées et quand elles circulent entre les systèmes.

## 3.1 Données

Trois techniques protègent les données. Le chiffrement les rend illisibles sans clé, la pseudonymisation remplace les identifiants directs par des codes, et l'anonymisation supprime définitivement le lien avec la personne.

- **Chiffrement au repos.** Tous les stockages sont chiffrés avec des clés KMS, sauvegardes comprises. Le chiffrement est activé par défaut à la création de chaque ressource, sans réglage manuel.
- **Chiffrement en circulation.** Aucun échange n'est en clair. Le TLS est imposé à l'entrée (WAF et API) pour les marchands et les sites, puis entre toutes les briques internes.
- **Pseudonymisation.** Les identifiants directs sont remplacés par des codes dans les systèmes d'analyse et de scoring. Les tables de log et de dimension de la BI ne contiennent ni e-mail, ni nom, ni valeurs modifiées. Le lien avec la personne n'existe que grâce à une clé conservée à part. Une donnée pseudonymisée reste une donnée personnelle au sens du RGPD. Seule l'anonymisation la fait sortir de ce cadre.
- **Anonymisation.** Quand une personne demande l'effacement de ses données, ses données sont anonymisées de façon irréversible. Les paiements sont conservés, car la loi l'impose, mais la personne n'est plus identifiable.

## 3.2 Clés et secrets

Le chiffrement n'est aussi solide que la protection de ses clés. Les clés et les secrets sont donc gérés par des services dédiés, jamais dans le code.

- **Clés (AWS KMS).** Une clé distincte est utilisée par domaine : paiements (Aurora), lakehouse (S3), collecte (DocumentDB et Kafka). Une clé compromise n'expose ainsi qu'un domaine. Les clés tournent automatiquement chaque année, l'équipe qui les utilise n'est pas celle qui les administre, et chaque usage est journalisé dans AWS CloudTrail.
- **Secrets (AWS Secrets Manager).** Identifiants des bases, accès à Kafka, jetons Databricks et clé de pseudonymisation y sont stockés. Ils ne figurent jamais dans le code, les images de conteneurs ni les fichiers Terraform. Ils sont renouvelés automatiquement et lisibles uniquement par des rôles IAM autorisés.

## 3.3 Tokenisation des cartes

La meilleure protection d'un numéro de carte est de ne **pas le détenir**. La plateforme ne manipule que des jetons, ce qui réduit fortement le périmètre PCI-DSS.

Dans payment_method, la plateforme conserve le jeton, la marque, les quatre derniers chiffres, le mois et l'année d'expiration, et le fingerprint. Le jeton remplace le numéro et reste inutilisable hors de Stripe. Le numéro complet, le cryptogramme et la piste magnétique ne sont jamais écrits dans Aurora, Kafka, le lakehouse, DocumentDB, Redis ni les journaux. Le fingerprint est une empreinte non réversible qui permet de repérer la même carte chez plusieurs clients. C'est une donnée personnelle : il est classé critique, et seul son hachage alimente les compteurs Redis.

## 3.4 Droits des personnes

Un client final peut demander l'accès à ses données ou leur effacement. La plateforme répond dans un délai d'un mois, avec le même parcours pour le RGPD et le CCPA.

- **Parcours d'une demande.** La demande est enregistrée dans data_subject_request. Le DPO l'instruit, l'équipe plateforme exécute l'opération technique, et la clôture est tracée dans le journal d'audit.
- **Droit d'accès.** Les données de la personne sont retrouvées par son identifiant client dans Aurora (customer, paiements) et, par lots, dans le lakehouse et DocumentDB. Les données pseudonymisées sont rattachées à la personne grâce à la clé de pseudonymisation.
- **Droit à l'effacement.** Les paiements doivent être conservés car c'est une obligation comptable de lutte contre le blanchiment. Donc, on n'efface donc pas tout, on supprime ou on anonymise ce qui n'a plus à être conservé, et on documente le reste.

**Note pour delalake et les sauvegardes :** Les sauvegardes Aurora et Delta Lake conservent encore les données pendant leur période de rétention. La rétention des sauvegardes est fixée à 30 jours maximum et le VACUUM s'exécute sous 7 jours : le délai effectif entre la demande et la suppression physique reste donc inférieur au délai d'un mois.

## 3.5 Tableau de synthèse

Pour chaque exigence, le tableau indique la mesure retenue et la preuve qui permet de la démontrer. Les mesures communes au RGPD et à PCI-DSS sont regroupées dans un socle commun, et chaque réglementation ne garde que ce qui lui est propre.

| Exigence | Mesure | Preuve |
|---|---|---|
| **Socle commun (RGPD et PCI-DSS)** | | |
| Chiffrer les données et protéger les clés | KMS et TLS partout, une clé par domaine, Secrets Manager | Configuration des ressources, journaux d'usage des clés |
| Limiter les accès au nécessaire | RBAC, IAM, Unity Catalog, revue trimestrielle | Revue des droits, historique des accès |

| | | |
|---|---|---|
| Journaliser et conserver les traces | CloudTrail, audit_log, Unity Catalog, Delta | Journaux protégés et conservés |
| **RGPD** | | |
| Minimiser les données et limiter leur durée de conservation | Pseudonymisation par défaut, TTL et durées par système (2.3, 3.1) | Schémas OLAP et NoSQL, suppression automatique constatée dans les logs |
| Répondre aux demandes d'accès et d'effacement dans le délai, dans tous les systèmes | Parcours data_subject_request, anonymisation, suppression et reconstruction (3.4) | Suivi des délais dans le tableau de bord, compteurs avant et après effacement |
| Garder les données de l'UE dans l'UE | Hébergement en région européenne | Configuration des régions |
| Notifier une violation sous 72 h | Procédure d'incident (6.3) | Registre des incidents |
| **CCPA** | | |
| Droit de savoir et de suppression | Même parcours que le RGPD | Suivi dans data_subject_request |
| Droit de refuser la vente ou le partage | A priori aucune vente de données personnelles chez Stripe | Déclaration documentée |
| **PCI-DSS** | | |
| Ne pas stocker les données de carte | Tokenisation, aucun numéro stocké | Schéma payment_method |
| Segmenter le réseau | Zones publique et privée, filtrage | Configuration réseau, contrôles automatisés |
| Surveiller et tester régulièrement | Surveillance et contrôles automatisés | Rapports de conformité |

# 4 Contrôle des accès

Protéger les données ne suffit pas : il faut aussi limiter qui peut les atteindre.

## 4.1 RBAC

Les droits sont attribués à des rôles, jamais à des personnes. Chaque rôle est celui d'un acteur de la gouvernance et ne reçoit que ce dont sa mission a besoin, c'est la règle du moindre privilège :

- **Séparer les usages.** Un rôle qui exploite les données ne les administre pas, et celui qui administre les clés ne lit pas les données.
- **Réduire l'exposition des données personnelles.** Seuls les rôles qui instruisent une demande de personne (DPO) voient les données directes. Les autres travaillent sur des données pseudonymisées.
- **Valider l'accès par le Data Owner.** C'est lui qui autorise l'accès aux données de son domaine.

## 4.2 Mise en œuvre

Deux outils appliquent ces règles : AWS IAM pour l'infrastructure, Unity Catalog pour les données du lakehouse.

- **AWS IAM.** Chaque rôle correspond à un rôle IAM limité aux ressources nécessaires. Les personnes se connectent avec une double authentification et reçoivent des droits temporaires, sans clé d'accès permanente. Les briques de la plateforme (scoring, Debezium, jobs Databricks) ont chacune leur propre rôle technique.
- **Unity Catalog.** Les droits sont donnés à des groupes, par schéma, table et colonne. Les colonnes sensibles sont masquées pour les rôles qui n'ont pas à les voir.
- **Revue des droits.** Les Data Owners revoient les droits par exemple chaque trimestre, et un départ ou un changement de poste retire les droits automatiquement.

## 4.3 Segmentation réseau

Les systèmes sensibles ne sont jamais exposés directement à Internet. Le réseau est découpé en zones, et chaque zone ne communique qu'avec celles dont elle a besoin.

- **Zone publique.** Seul le paiement et la collecte est joignable depuis Internet.
- **Zone privée.** Les autres n'ont pas d'adresse publique.
- **Filtrage.** Chaque brique n'accepte que les flux nécessaires, par des règles de groupes de sécurité.
- **Environnements test & prod.** Développement et production sont séparés et invisible l'un par rapport à l'autre, et aucune donnée réelle ne sert aux tests.

# 5 Journal d'audit

Prouver qu'une plateforme est sécurisée suppose de pouvoir retracer qui a fait quoi, quand et sur quelle donnée.

## 5.1 Ce qui est journalisé et où

- **Actions sur l'infrastructure (AWS CloudTrail).** Toute action sur les ressources AWS est enregistrée : création ou modification d'une ressource, changement de droits, usage d'une clé KMS, lecture d'un secret.
- **Modifications des données de paiement (audit_log, Aurora).** Chaque modification d'une table est enregistrée avec le nom de la table, l'identifiant de la ligne, l'action, les noms des colonnes modifiées, l'auteur et la date. Les valeurs ne sont jamais copiées, pour éviter le stockage de données personnelles.
- **Accès et modifications dans le lakehouse (Unity Catalog et Delta).** Unity Catalog dans Databricks enregistre qui lit quelle table et quelle colonne, et conserve le lignage. Delta enregistre chaque version d'une table avec DESCRIBE HISTORY, ce qui permet de savoir qui a modifié quoi.
- **Journaux métier (fraud_assessment et data_subject_request, Aurora).** Chaque décision de fraude garde son score, ses motifs et la version du modèle qui l'a prise, ce qui permet d'expliquer pourquoi un paiement a été refusé. Chaque demande d'accès ou d'effacement est suivie, ce qui prouve qu'elle est traitée dans le délai d'un mois.

## 5.2 Protection des journaux

- **Intégrité.** Les journaux CloudTrail sont stockés dans un bucket S3 dédié, en écriture seule et avec vérification d'intégrité. Aucun rôle d'exploitation ne peut les modifier ni les supprimer. Les tables audit_log et outbox sont en ajout seul, comme le reste de l'OLTP.
- **Confidentialité.** Seuls l'équipe Sécurité et le DPO lisent les journaux d'audit. Ils sont chiffrés et ne contiennent aucune donnée personnelle directe.
- **Conservation.** Les journaux d'audit sont conservés pendant la durée légale.
- **Séparation des comptes.** Les journaux sont écrits dans un compte AWS distinct de celui de la production, pour qu'un incident sur la production ne puisse pas les effacer.

# 6 Surveillance et rapports

Les mesures des chapitres précédents ne valent que si elles restent actives dans le temps.

## 6.1 Surveillance continue

AWS CloudWatch collecte les journaux et les métriques de toutes les briques, et alerte l'équipe Sécurité dans les cas suivants : accès refusés répétés, usage inhabituel d'une clé KMS ou d'un secret, modification d'un droit ou d'une règle réseau, lecture massive de données, et désactivation d'un chiffrement ou d'un journal. Les alertes de sécurité s'ajoutent à celles du pipeline (livrable 4) et du scoring (livrable 5).

## 6.2 Contrôles et rapports quotidiens

Chaque jour, des contrôles automatiques vérifient que les mesures sont toujours en place : chiffrement actif sur tous les stockages, absence de ressource exposée sur Internet en dehors de l'entrée (WAF et API), absence de droits excessifs ou de comptes inutilisés, application des durées de conservation (TTL, VACUUM), respect du délai d'un mois pour les demandes des personnes, et absence de donnée de carte ou de donnée personnelle directe dans les systèmes d'analyse.

Un rapport de conformité est produit à partir de ces résultats. Il est adressé au DPO et à l'équipe Sécurité, et le CDO reçoit une synthèse mensuelle. Tout écart ouvre une alerte et reste tracé jusqu'à sa correction. Un tableau de bord de KPI permet de visualiser rapidement l'état de la surveillance continue.

## 6.3 Incident et notification de violation

En cas de violation de données, la réaction suit une procédure connue à l'avance.

L'équipe Sécurité qualifie l'incident, isole les systèmes concernés, puis évalue les données touchées avec l'aide des journaux d'audit (chapitre 5). Le DPO notifie l'autorité de contrôle dans les 72 heures si des données personnelles sont concernées, et informe les personnes quand le risque pour elles est élevé. Chaque incident est inscrit dans un registre, avec ses causes et les mesures correctives.